

Master Governance Amendment

001

Document:

`docs/architecture/MASTER_GOVERNANCE_AMENDMENT_001.md`

System: HackNest — Student Operating System

Status: Foundational / Authoritative — closes the last fully-missing Governance-layer document

Type: Governance Specification Only — No Implementation

Follows `README.md` and `MASTER_ARCHITECTURE.md` exactly, occupying the Governance layer position reserved for it. Per `MASTER_ARCHITECTURE.md` Section 9, this document is the sole authoritative owner of: approval authority, the architecture change/amendment process, and every numeric operational target that other documents deferred pending its existence (secret rotation cadence, RPO/RTO, rate-limit tiers, WCAG level, retention windows, escalation timing). This amendment supersedes every "interim" placeholder in `MASTER_ARCHITECTURE.md`, `SECURITY_ARCHITECTURE.md`, and `OPERATIONS_ARCHITECTURE.md` that named it as the pending source of truth.

1. Purpose of This Amendment

MASTER_ARCHITECTURE.md Section 5 established an interim rule: until this document existed, approval authority rested with whoever held final review authority over the repository, and numerous documents flagged numeric targets as placeholders pending this amendment. This document formally replaces every one of those interim placeholders with a real, citable decision.

2. Governance Authority Structure

- **Architecture Owner** — final approval authority over any change to docs/architecture/ itself (this document, MASTER_ARCHITECTURE.md , or any subsystem document). One designated role, not a committee, to keep decisions fast and unambiguous.
- **Security Reviewer** — required co-approver (alongside the Architecture Owner) for any change touching SECURITY_ARCHITECTURE.md , authentication, authorization, or the Audit Log specification in DATABASE_ARCHITECTURE.md .
- **Release Approver** — authority defined in DEPLOYMENT_ARCHITECTURE.md 's Deployment Approval gate; may be the same individual as the Architecture Owner but is a distinct *function*, since architecture approval and release approval answer different questions (is this the right design vs. is this specific build safe to ship now).
- **Incident Commander (rotating, on-call)** — holds temporary elevated decision authority during an active Critical incident, per SECURITY_ARCHITECTURE.md

Section 23 and `OPERATIONS_ARCHITECTURE.md`'s Alerting section, including the disclosure decisions that document flagged as pending this amendment. That authority reverts to the Architecture Owner once the incident is closed.

This structure formally satisfies every "interim approval authority" and "disclosure-decision authority" placeholder in `MASTER_ARCHITECTURE.md`, `SECURITY_ARCHITECTURE.md`, and `OPERATIONS_ARCHITECTURE.md`.

3. Architecture Amendment Process

Formalizes and supersedes the interim process in `MASTER_ARCHITECTURE.md` Section 11:

1. A proposed change is written against the specific document(s) it affects, citing `MASTER_ARCHITECTURE.md` Section 9's ownership table to confirm it doesn't redefine a concern owned elsewhere.
2. Every document that cites the affected concern is identified and checked for consistency.
3. The **Architecture Owner** approves; the **Security Reviewer** additionally co-approves if the change is security-adjacent (per Section 2 above).
4. If the change adds a new domain, role, or subsystem document, `MASTER_ARCHITECTURE.md` Sections 4–5 are updated in the same change to remain the current canonical list.
5. Merged changes are versioned per `MASTER_ARCHITECTURE.md` Section 10.

4. Production Numeric Targets

This section is the authoritative source for every numeric value previously deferred across the document set. Each entry states the value, which document operationally enforces it, and why the value was chosen.

4.1 Rate Limiting Tiers (*owned operationally by `API_ARCHITECTURE.md`, defined here*)

Category	Limit	Rationale
Authentication (sign-in, sign-up)	10 requests / 5 minutes per IP; 5 requests / 5 minutes per account	Tight enough to blunt credential stuffing without blocking a legitimate student mistyping a password a few times.
Password reset / email verification	3 requests / 15 minutes per account or email	Prevents reset-flow abuse and mail-bombing while allowing genuine retry.
General authenticated reads (GET-equivalent)	300 requests / minute per account	High enough not to interfere with normal UI polling/navigation.
Mutating actions (writes, Server	60 requests / minute per	Generous for real usage, restrictive

Category	Limit	Rationale
Actions)	account	enough to blunt scripted abuse.
Messaging (send message)	30 messages / minute per account	Prevents spam/flooding in Chat while supporting rapid real conversation.
Search	60 queries / minute per account	Balances responsive UX against index load.
Unauthenticated public reads (e.g., public Hackathon listings)	100 requests / minute per IP	Protects public surfaces from scraping without blocking normal browsing.
File upload	20 uploads / hour per account	Bounds storage/scanning load per identity.

4.2 Recovery Objectives (*owned operationally by DEPLOYMENT_ARCHITECTURE.md, defined here*)

Target	Value	Rationale
RPO (Recovery Point Objective)	15 minutes	Matches a continuous/frequent backup posture appropriate for student-

Target	Value	Rationale
		generated data where losing more than a quarter-hour of activity (team formation, messages, submissions) is unacceptable, especially near hackathon deadlines.
RTO (Recovery Time Objective)	4 hours for full restoration; 1 hour for critical-path services (Authentication, core read availability) restored in a degraded-but-functional mode	Reflects that a multi-day outage is unacceptable for a platform students depend on around fixed deadlines, while acknowledging full parity restoration reasonably takes longer than the most critical path.

4.3 Backup Policy (*owned operationally by*

DEPLOYMENT_ARCHITECTURE.md, defined here)

- **Frequency:** continuous write-ahead log backup plus a full snapshot every 6 hours, consistent with the 15-minute RPO above.
- **Retention:** rolling 35 days of point-in-time recovery capability; monthly snapshots retained for 12 months for longer-horizon recovery/compliance needs.

- **Testing cadence:** a full restore is rehearsed against a non-production environment quarterly, per `OPERATIONS_ARCHITECTURE.md` 's Disaster Recovery Testing requirement.

4.4 WCAG Conformance Level (*owned operationally by `UI_DESIGN_SYSTEM.md`, defined here*)

- **Target: WCAG 2.2 Level AA**, the widely-adopted standard balancing genuine accessibility with practical achievability, applied to every shipped UI surface per `TESTING_STRATEGY.md` 's Accessibility Testing.

4.5 Performance Targets (*owned operationally by `TESTING_STRATEGY.md`, defined here*)

Interaction Class	Target (p95)
Interactive API reads (profile, team, project fetch)	< 300ms
Search queries	< 500ms
Mutating actions (Server Actions)	< 500ms
Page navigation (server-rendered)	< 1.5s to interactive
File upload acknowledgment (excluding transfer time)	< 1s

4.6 Concurrency / Scaling Targets (*owned operationally by `DEPLOYMENT_ARCHITECTURE.md` and*

DATABASE_ARCHITECTURE.md, **defined here**)

- **Steady-state concurrency:** system sized for 50,000 concurrent active sessions at general-availability scale.
- **Burst concurrency:** system must sustain 5x steady-state (250,000 concurrent sessions) during a burst window (e.g., a major hackathon's submission deadline) without falling outside the Section 4.5 targets by more than 2x, per *TESTING_STRATEGY.md*'s Stress Testing.
- **Long-term scale target:** confirmed at 1,000,000 registered students per *MASTER_ARCHITECTURE.md* Section 15, with *DATABASE_ARCHITECTURE.md* Section 13's partitioning candidates (Messages, Audit Logs, Notifications, Feed) triggered when any one of those tables exceeds 50 million rows or its 95th-percentile query time exceeds the Section 4.5 target by 2x, whichever comes first.

4.7 Security Requirements — Concrete Cadences **(owned operationally by *SECURITY_ARCHITECTURE.md*** **and *OPERATIONS_ARCHITECTURE.md*, **defined here**)**

Item	Value
Secret rotation cadence (routine)	Every 90 days
Secret rotation cadence (suspected exposure)	Immediately, within 1 hour of confirmation

Item	Value
Access review cadence (admin / moderator / service role assignments)	Every 30 days
Audit log sampling review cadence	Weekly
Critical alert acknowledgment window before escalation	5 minutes
Warning alert acknowledgment window	4 hours
Vulnerability remediation SLA – Critical	24 hours
Vulnerability remediation SLA – High	7 days
Vulnerability remediation SLA – Medium	30 days

4.8 Data Retention Windows (*owned operationally by DATABASE_ARCHITECTURE.md, defined here*)

Category	Retention
Audit Logs	Permanent (no override)
Security logs	2 years
Application/Error/Access logs	90 days

Category	Retention
Notifications	180 days after read, 1 year if unread
Activity Feed entries	180 days
Soft-deleted student content (grace period before hard delete)	30 days
Account deletion (full propagation deadline across all domains)	30 days from request, per Section 6 below

5. Approval Sign-off Requirements by Change Type

Change Type	Required Approvers
New domain or role	Architecture Owner + Security Reviewer
Authentication/authorization change	Architecture Owner + Security Reviewer
New numeric target or revision to Section 4	Architecture Owner
Roadmap phase re-sequencing	Architecture Owner

Change Type	Required Approvers
Release to Production	Release Approver (per <code>DEPLOYMENT_ARCHITECTURE.md</code>)
Incident-driven emergency change	Incident Commander (during incident), ratified by Architecture Owner post-incident

6. Closing the Account-Deletion Ownership Gap

`SECURITY_ARCHITECTURE.md`'s reconciliation flagged that no `IMPLEMENTATION_ROADMAP.md` phase explicitly owns cross-domain account-deletion propagation. This amendment formally assigns that ownership to **Phase 021 (Settings)**, with a 30-day propagation deadline per Section 4.8 above: on a deletion request, every domain holding data identity-owned by that student (per `DATABASE_ARCHITECTURE.md` Section 3) must complete its soft-delete-then-purge cycle within 30 days, coordinated by a deletion-orchestration responsibility that Phase 021's Deliverables must include on its next roadmap revision.

Definition of Done

- [x] Governance specification only — no implementation.
- [x] Follows `README.md` and `MASTER_ARCHITECTURE.md` exactly.

- [x] Supersedes every interim placeholder those documents named as pending this amendment.
 - [x] Every previously-deferred numeric target now has a concrete value.
-

Validation Report

Internal consistency: every numeric target is stated exactly once (Section 4), with clear operational-ownership cross-references rather than duplication. No contradiction found.

Consistency with governing documents: confirms and fulfills the interim-authority placeholders in `MASTER_ARCHITECTURE.md` Section 5, `SECURITY_ARCHITECTURE.md` Sections 12/17/20/23, and `OPERATIONS_ARCHITECTURE.md`'s Logging/Alerting/Capacity Planning/Operational Security sections. Does not redefine any concern already owned elsewhere (e.g., does not restate the audit log record shape, only its retention window).

Outstanding follow-up: the subsystem documents that deferred these values (`API_ARCHITECTURE.md` , `DEPLOYMENT_ARCHITECTURE.md` , `UI_DESIGN_SYSTEM.md` , `TESTING_STRATEGY.md` , `SECURITY_ARCHITECTURE.md` , `DATABASE_ARCHITECTURE.md`) should be revised to cite Section 4 of this document directly rather than continuing to say "pending governance guidance." This is addressed in this same work session's subsequent reconciliation passes.

Status: Validated — Governance Layer Complete